

Password & MFA Policy

Owner: Mark Stolte, Founder — markstolte02@gmail.com

Last reviewed: 2026-07-05

Stage: Pre-launch / active development

Purpose

Describes how Penny Pilot authenticates end users and what MFA is required for the operator/admin accounts that run the product. Split into those two halves deliberately, since they work differently.

End-user authentication

Penny Pilot **does not implement its own password store**. There is no `password` column, no password hashing routine, and no "forgot password" flow in this codebase. Sign-in is delegated entirely to Supabase Auth, configured with Apple and Google as the only providers ([docs/auth-provider-setup.md](#)), using the OAuth PKCE flow ([src/services/supabase-client.ts](#)).

Practical consequences:

- Password strength, password rotation, and account-recovery flows are Apple's and Google's responsibility, not Penny Pilot's — both providers already meet or exceed typical password-policy requirements (length, breach-list checks, recovery flows) for their own accounts.
- **MFA for end users** is likewise delegated: any user who has 2-factor authentication enabled on their Apple ID or Google account gets that protection on their Penny Pilot sign-in automatically, with no additional configuration in this app. Penny Pilot cannot weaken or bypass a user's Apple/Google MFA.
- The session token Supabase issues after sign-in is stored via `expo-secure-store` (iOS Keychain / Android Keystore) on native platforms. On the web build, it falls back to `localStorage` — this fallback exists only for local development/preview convenience and is a known, accepted limitation of the web target, not the production auth path (the shipped app is native).
- Session refresh is automatic (`autoRefreshToken: true`) and Penny Pilot does not persist the underlying Apple/Google credential — only the Supabase-issued session.

If Penny Pilot ever adds email/password sign-in as an option, this policy must be updated first to define a password policy (minimum length, breach-list check, hashing algorithm) and to require MFA enrollment, before that flow ships.

Operator/admin account requirements

Every system listed in the [Access Control Policy](#) table (GitHub, Supabase, Plaid, Apple Developer, Google Cloud/Play Console, Expo/EAS) must have:

- A unique, randomly generated password stored in a password manager — no reused or human-memorable passwords for these accounts.
- Multi-factor authentication enabled, using an authenticator app or hardware key rather than SMS where the provider supports it.

System	MFA required	Status
GitHub	Yes	Founder-managed; verify enrollment at each policy review.
Supabase dashboard	Yes	Founder-managed; verify enrollment at each policy review.
Plaid dashboard	Yes	Founder-managed; verify enrollment at each policy review.
Apple Developer / App Store Connect	Yes (Apple ID 2FA is mandatory)	Enforced by Apple.
Google Cloud / Play Console	Yes	Founder-managed; verify enrollment at each policy review.
Expo/EAS	Yes	Founder-managed; verify enrollment at each policy review.

"Founder-managed" statuses above are self-attested rather than independently audited, which is appropriate for a one-person team; this table is re-verified at each policy review (see [Risk Assessment Process](#)) rather than assumed.

Future team growth

When a second person is granted access to any operator/admin system, they must enable MFA on that system before receiving credentials, and their access must be revocable independently of the founder's (i.e., a named account, not a shared login).